

Transcript-Bound Combiners for Downgrade-Resilient Hybrid Post-Quantum Key Establishment: Definition, Proof, and Embedded-Device Cost

Bhanwar Gupta^{1*} and Sanjeev Rana¹

¹*Department of Computer and Software Engineering, Maharishi
Markandeshwar (Deemed to be University), Mullana, Ambala, 133207,
Haryana, India.

*Corresponding author(s). E-mail(s): bgupta55@gmail.com;

Contributing authors: sanjeev.rana@mmumullana.org;

Abstract

Hybrid key establishment runs a post-quantum key-encapsulation mechanism (KEM) alongside a classical Diffie-Hellman primitive, so that the session key stays secure while either component resists attack. This design is now standardized in the Transport Layer Security protocol, Secure Shell, and the Internet Key Exchange, with the standardized module-lattice KEM (ML-KEM) as the post-quantum component. A hybrid KEM secures the derived key, but not the integrity of the negotiation that selects which primitives are used. Full protocols authenticate that negotiation through a handshake transcript; a hybrid KEM deployed as a standalone drop-in primitive, or inside a minimal handshake without transcript authentication, inherits no such guarantee, and an active attacker can strip the post-quantum option. We ask what the key schedule alone must contain to make downgrade resilience a local property of the combiner. We give a game-based definition at the combiner layer and prove a two-sided separation: a combiner that ignores the transcript is downgraded with certainty, whereas one that binds the session key and the confirmation tag to a hash of the transcript blocks every such attempt, up to a term negligible for a 256-bit transcript hash. We also give an explicit strongest-link security bound. Using a calibrated cost model composed from published Cortex-M4 measurements, transcript binding adds one hash per party—about 11.8% of handshake computation but only 1.5% of radio-inclusive energy—and adds no messages or bytes on the wire.

Every reported number is produced by a released harness that passes a 30-check validation gate.

Keywords: post-quantum cryptography, hybrid key encapsulation, downgrade resilience, ML-KEM, transcript binding, constrained devices

1 Introduction

Shor’s algorithm solves the discrete-logarithm and integer-factoring problems efficiently on a large quantum computer [1]. The public-key primitives underlying today’s infrastructure—RSA, elliptic-curve Diffie–Hellman, and DSA—all rest on one of these problems. The timeline for a cryptographically relevant quantum computer is uncertain, but a harvest-now, decrypt-later adversary records encrypted traffic today and decrypts it once such a machine exists. Quantum-resistant key establishment must therefore be deployed before the machine arrives.

NIST’s first standardization round concluded in 2024 with ML-KEM (FIPS 203), ML-DSA (FIPS 204), and SLH-DSA (FIPS 205) [2–5]. ML-KEM, descended from CRYSTALS-Kyber [6], is the designated key-encapsulation mechanism (KEM). Its security rests on the Module Learning-With-Errors problem, a lattice assumption that is young relative to the decades of cryptanalysis behind elliptic-curve Diffie–Hellman. The classical break of SIKE in 2022 [7] illustrates how quickly confidence in a new assumption can erode [8].

The pragmatic response, already standardized in the Transport Layer Security (TLS) protocol, Secure Shell, and the Internet Key Exchange, is the hybrid KEM. Two peers run a post-quantum KEM and a classical Diffie–Hellman primitive in parallel and derive one session key from both shared secrets. The channel stays secure as long as either primitive survives. Internet-scale experiments with hybrid key exchange [9, 10] and later TLS performance studies [11, 12] established that the approach is practical, and its TLS 1.3 design rationale is documented in an IETF draft [13].

1.1 The negotiation problem

A hybrid KEM secures the *key* once both parties have agreed on which suite to use. It says nothing about the integrity of the *negotiation* that precedes that agreement. In a configurable deployment, each device advertises the suites it supports and the peers select one. An attacker who controls the network can intercept those advertisements, delete the post-quantum option, and force both peers onto a classical-only handshake that neither would have chosen.

This threat is concrete. The Logjam attack forced TLS peers onto export-grade Diffie–Hellman that the attacker could then factor in real time [14]. The analogous move during the quantum transition strips the post-quantum KEM, so two peers that prefer hybrid security complete a purely classical handshake—the exact outcome that motivated deploying ML-KEM.

Standardized full protocols already prevent this. TLS 1.3 folds the negotiated parameters into a hash of the complete handshake transcript and authenticates that hash in a Finished message [15]; Bhargavan et al. formalized this pattern and proved it yields downgrade resilience at the protocol layer [16]. A hybrid KEM embedded in TLS 1.3 inherits that protection. The lightweight authenticated key exchange EDHOC [17] likewise secures its cipher-suite negotiation: the initiator’s advertised list is processed so that the responder can verify the selected suite is the initiator’s most preferred mutually supported one, giving downgrade-protected negotiation even on constrained devices.

1.2 The gap and this work

The gap appears when a hybrid KEM is used *outside* a protocol that binds the negotiation. This is not a corner case. A modern hybrid KEM such as X-Wing [18] is deliberately specified as a standalone drop-in primitive with no notion of negotiation, so that it can replace a single KEM anywhere; its own security relies on the surrounding protocol for non-malleability of context. An implementer who pairs two raw KEMs in a bespoke minimal handshake, or who adds a hybrid suite to a custom constrained-device protocol without replicating transcript authentication, obtains a combiner whose key schedule is blind to what was advertised. As we show, a downgrade attack then succeeds with certainty. In such a deployment, downgrade resilience is only as reliable as the correctness of a protocol layer that the combiner cannot see.

We ask a sharp question: what is the minimal change to the hybrid key schedule that makes downgrade resilience a *local* property of the combiner, independent of whether the surrounding protocol authenticates the transcript?

The answer is one hash. Including a hash of the negotiation transcript in the inputs to both the key-derivation function and the key-confirmation code binds the derived session key to the parameters that were actually observed. If an attacker rewrites those parameters, the two parties assemble different transcripts, derive different keys, and the initiator’s tag verification fails and aborts. No extra messages, round trips, public-key operations, or wire bytes are introduced.

We are explicit about the size of this claim. The security mechanism is a direct, expected specialization of the transcript-binding principle of Bhargavan et al. [16] from the protocol layer to the combiner layer; we do not claim a new cryptographic technique. Our contribution is the combiner-local definition and instantiation, a concrete two-sided bound with an explicit constant for this specific construction, and an engineering-cost account of the mechanism on constrained hardware.

Contributions.

1. A game-based definition of downgrade resilience for hybrid key establishment at the combiner layer, with an active man-in-the-middle adversary, Send oracles, and a matching predicate for the bad event (Section 4).
2. A two-sided separation (Section 6): the combiner that ignores the transcript is downgraded with probability 1; the transcript-bound combiner has downgrade advantage at most $q_H/2^n + \text{Adv}_{\text{MAC}}^{\text{euf-cma}}$, with n the transcript-hash length. Both sides are confirmed in executed code.

3. An explicit strongest-link IND-CCA bound for the concrete combiner, with reductions to the component KEMs in the random-oracle model (Section 6), corroborated by an exposed-component distinguisher whose success rate tracks the analytic term with $R^2 = 0.98$.
4. An engineering account for constrained devices: a constant-time discussion of the added mechanism, and a calibrated cost model composed from published Cortex-M4 per-primitive measurements [19, 20] with a radio-inclusive energy budget (Sections 7 and 8).
5. A worked mapping of the combiner into an EDHOC message flow, and a released harness whose 30-check validation gate must pass before any number is reported (Section 7, Appendices).

Worked motivation.

Consider an initiator I and a responder R that both prefer the hybrid suite `mlkem768_x25519` but also advertise classical `x25519` for interoperability, paired directly through a combiner rather than through TLS or EDHOC. With the plain combiner $K = \text{KDF}(K_{\text{pq}} \parallel K_{\text{ec}})$, an attacker deletes every post-quantum entry from both advertised lists. R sees only `x25519`, selects it, and both parties derive a purely classical key, because the key schedule never recorded what was advertised. We reproduce this downgrade at a 100% rate. Binding the key to a hash of the transcript closes the gap: the transcripts diverge, the keys diverge, and the handshake aborts every time.

2 Background and Notation

2.1 Cryptographic primitives

A KEM is a triple (KeyGen, Encaps, Decaps). KeyGen outputs an encapsulation key ek and a decapsulation key dk ; Encaps(ek) outputs a shared secret K and a ciphertext c ; Decaps(dk, c) recovers K . A KEM is IND-CCA secure if no efficient adversary distinguishes the real shared secret from a random one, even with a decapsulation oracle, except with negligible advantage.

We instantiate the post-quantum component with ML-KEM-768 [2], whose IND-CCA security follows from a Fujisaki–Okamoto-style transform over Module-LWE [6, 21]. We treat X25519 [22, 23] as a nominal-group Diffie–Hellman KEM. The key-derivation function KDF and transcript hash H are SHAKE-256 and SHA3-256 [24]; key confirmation uses HMAC-SHA3-256 as the message authentication code MAC [25, 26]. Table 1 lists all notation. Multi-letter operators such as KDF, MAC, H , and Adv are upright.

2.2 Hybrid combiners

A combiner turns two component shared secrets into one session key. The two combiners we compare share an identical protocol skeleton and differ only in the key schedule:

$$\text{Plain: } K = \text{KDF}(K_{\text{pq}} \parallel K_{\text{ec}}), \quad (1)$$

Table 1 Notation used throughout the paper.

Symbol	Meaning
I, R	Initiator and responder
$\mathcal{A}$	Active man-in-the-middle adversary
K_{pq}, K_{ec}	ML-KEM-768 and X25519 shared secrets
ek, dk, c	Encapsulation key, decapsulation key, ciphertext
A_I, A_R	Advertised cipher-suite lists
τ	Handshake transcript as observed by one party
ℓ	Domain-separation label
K	Derived session key
$H, \text{KDF}, \text{MAC}$	Hash, key-derivation function, message authentication code
q_H	Adversary’s random-oracle query budget
n	Transcript-hash output length in bits
γ	$\min(K_{pq} , K_{ec})$ in bits
$\text{Adv}^X(\mathcal{A})$	Advantage of $\mathcal{A}$ in game X

$$\text{Bound: } K = \text{KDF}(\ell \parallel K_{pq} \parallel K_{ec} \parallel H(\tau)), \quad (2)$$

where τ is the ordered concatenation of every handshake message as the local party observed it, including both advertised suite lists and the selected suite. The confirmation tag from the responder is $\text{MAC}(K, \text{"finished"})$ for the plain variant and $\text{MAC}(K, \tau)$ for the bound variant. Equation (2) is the only change we advocate.

The intuition is direct. In the plain combiner, K is a function of only the two shared secrets, so rewriting the advertised lists leaves no trace in K : the two parties derive the same key even though they negotiated on different lists. In the bound combiner, K also depends on $H(\tau)$. If an attacker alters the lists, the parties assemble different transcripts $\tau_I \neq \tau_R$, derive different keys $K_I \neq K_R$ except with negligible probability, and the initiator’s verification of the responder’s tag fails.

3 Related Work

KEM combiners and hybrid KEMs.

Giacon, Heuer, and Poettering formalized KEM combiners and proved that a split-key pseudorandom-function core achieves IND-CCA security whenever one component KEM is secure [27]. Bindel et al. extended hybrid guarantees to authenticated key exchange and to quantum adversaries in the quantum random-oracle model (QROM) [28]; Huguenin-Dumittan and Vaudenay analysed Fujisaki–Okamoto-style combiners in the same setting [29]. The closest concrete design is X-Wing [18], which fixes ML-KEM-768 and X25519 and proves IND-CCA security using SHA3-256. X-Wing is a standalone KEM: it omits negotiation by design so it can serve as a drop-in primitive, and its specification notes that non-malleability of surrounding context is provided by the embedding protocol. These works establish the strongest-link guarantee our combiner inherits; none models suite negotiation or defines downgrade resilience at the combiner layer.

Hybrid authenticated key exchange.

Dowling, Hansen, and Paterson give a framework for provably quantum-secure hybrid authenticated key exchange with whole-protocol security against component compromise [30]. Our scope is narrower by design: a combiner-level property, its proof, and its cost, rather than a full authenticated key exchange model.

Downgrade resilience.

Bhargavan et al. introduced downgrade resilience as a formal notion for key-exchange protocols and identified the transcript-binding patterns that guarantee it [16]; TLS 1.3 [15] and EDHOC [17] adopt those patterns. Logjam is the canonical real-world downgrade attack [14]. We apply the same principle inside the combiner’s key schedule, so that the guarantee holds even when the embedding protocol does not provide it, and we give a combiner-specific quantitative bound.

Post-quantum and constrained key exchange.

KEMTLS replaces handshake signatures with KEMs [31]. Hybrid and post-quantum TLS and SSH have been prototyped and benchmarked [11, 12, 32]. For constrained nodes [33], EDHOC provides lightweight authenticated Diffie–Hellman over CoAP and OSCORE [17, 34, 35].

Embedded and physical-security engineering of ML-KEM.

Because our cost claims target constrained devices, we position the mechanism against the embedded ML-KEM literature. The pqm4 framework is the standard reference for Cortex-M4 cycle and memory measurements of ML-KEM [19], and Lenngren’s assembly implementation is the standard optimized X25519 for the same core [20]. Side-channel resistance for lattice KEMs is an active area: masking Kyber at first and higher orders [36], first-order masked Kyber on Cortex-M4 [37], efficient masking-conversion techniques [38], and demonstrated side-channel attacks on masked lattice KEMs [39]. This body of work matters here for two reasons: it fixes the per-primitive costs our model composes, and it sets the scale against which the binding overhead should be read—a masked ML-KEM-768 decapsulation costs roughly an order of magnitude more than one unmasked decapsulation, so a single transcript hash is negligible in any side-channel-hardened deployment (Section 7).

Table 2 positions this work against the closest prior contributions. A check mark in *SL* means the work proves a strongest-link IND-CCA guarantee; *DR* means it establishes downgrade resilience; *Neg* means it explicitly models suite negotiation; *M4* means it reports Cortex-M4 cost data for the construction. Our contribution is the row that combines all four.

4 Problem and Threat Model

4.1 Setting

Two honest parties, initiator I and responder R , each hold a local configuration listing the cipher suites they support, drawn from $\{\text{mlkem768_x25519}, \text{mlkem768}, \text{x25519}\}$

Table 2 Comparison with the closest prior work. SL: strongest-link IND-CCA; DR: downgrade resilience; Neg: suite negotiation modelled; M4: Cortex-M4 cost data.

Work	SL	DR	Neg	M4
Giacon et al. [27]	✓			
Bindel et al. [28]	✓			
X-Wing [18]	✓			
Dowling et al. [30]	✓			
Bhargavan et al. [16]		✓	✓	
This work	✓	✓	✓	✓

and ranked by a public strength order with the hybrid suite strongest. They negotiate the strongest mutually supported suite. The message flow mirrors hybrid key-share negotiation in TLS 1.3, IKEv2, and lightweight constrained key exchange: I sends its advertised list and key shares; R selects the strongest mutual suite, performs the KEM or Diffie–Hellman operation, and returns its list, selection, shares, and a confirmation tag; I completes and verifies the tag. Entity authentication is assumed to be provided by the embedding protocol or by pre-shared credentials; our concern is the integrity of the negotiated parameters.

4.2 Adversary

The adversary $\mathcal{A}$ is an active man-in-the-middle with full network control. It may read, drop, reorder, and rewrite any handshake message, including the advertised lists and the selected suite. It does not break the underlying primitives, and it makes at most q_H random-oracle queries. This is the standard downgrade setting of Bhargavan et al. [16].

Definition 1 (Downgrade resilience) Consider the game $\mathbf{G}_{\Pi}^{\text{dr}}$ in which a challenger initializes honest parties I and R whose configurations share a strongest mutual suite s^* , and runs one handshake with all messages routed through $\mathcal{A}$ via **Send** oracles that deliver $\mathcal{A}$ ’s chosen bitstrings. $\mathcal{A}$ wins if some honest session completes on a suite weaker than s^* . The advantage is $\text{Adv}_{\Pi}^{\text{dr}}(\mathcal{A}) = \Pr[\mathcal{A} \text{ wins } \mathbf{G}_{\Pi}^{\text{dr}}]$. Π is downgrade-resilient if this advantage is negligible for every efficient $\mathcal{A}$.

The bad event is an honest session accepting a key derived from fewer or weaker primitives than both parties were willing to support. This captures an attacker stripping the post-quantum option and forcing a classical-only handshake between two peers that both preferred hybrid security.

5 The Transcript-Bound Combiner

The construction is Equation (2), specified in Algorithm 1. The key design decision is that each party assembles τ from the messages exactly as it received them: I includes

Algorithm 1 Transcript-bound hybrid key establishment. The plain combiner replaces lines 7 and 12 with $K = \text{KDF}(K_{\text{pq}} \parallel K_{\text{ec}})$ and uses a constant string as the confirmation input.

```

1: Initiator  $I$ :  $(ek, dk) \leftarrow \text{KeyGen}_{\text{pq}}; (sk_I, pk_I) \leftarrow \text{KeyGen}_{\text{ec}}$ 
2:  $I \rightarrow R$ :  $A_I, ek, pk_I$ 
3: Responder  $R$ :  $s \leftarrow$  strongest mutual suite from  $(A_I, A_R)$ 
4:   if  $s$  uses pq:  $(K_{\text{pq}}, c) \leftarrow \text{Encaps}(ek)$ 
5:   if  $s$  uses ec:  $(sk_R, pk_R) \leftarrow \text{KeyGen}_{\text{ec}}; K_{\text{ec}} \leftarrow sk_R \cdot pk_I$ 
6:    $\tau_R \leftarrow (A_I, A_R, s, ek, c, pk_I, pk_R)$ 
7:    $K_R \leftarrow \text{KDF}(\ell \parallel K_{\text{pq}} \parallel K_{\text{ec}} \parallel \text{H}(\tau_R)); t_R \leftarrow \text{MAC}(K_R, \tau_R)$ 
8:  $R \rightarrow I$ :  $A_R, s, c, pk_R, t_R$ 
9: Initiator  $I$ : if  $s$  uses pq:  $K_{\text{pq}} \leftarrow \text{Decaps}(dk, c)$ 
10:   if  $s$  uses ec:  $K_{\text{ec}} \leftarrow sk_I \cdot pk_R$ 
11:    $\tau_I \leftarrow (A_I, A_R, s, ek, c, pk_I, pk_R)$ 
12:    $K_I \leftarrow \text{KDF}(\ell \parallel K_{\text{pq}} \parallel K_{\text{ec}} \parallel \text{H}(\tau_I))$ 
13:   if  $\text{MAC}(K_I, \tau_I) \neq t_R$  then abort else accept  $K_I$ 

```

its own advertised list and what it received from R ; R includes what it received from I together with its own list and its selection. Both the session key and the confirmation tag are bound to $\text{H}(\tau)$.

If $\mathcal{A}$ rewrites the negotiation—for instance by deleting post-quantum entries—the parties assemble different transcripts $\tau_I \neq \tau_R$. Because $\text{H}(\tau)$ enters the KDF input, the two keys K_I and K_R differ except with negligible probability, so the initiator’s check $\text{MAC}(K_I, \tau_I) = t_R$ fails and the handshake aborts. An attacker who leaves the transcript intact cannot downgrade: the parties agree on s^* and derive K from the hybrid primitive.

The label ℓ provides domain separation between combiners built on the same primitives, and the length-prefixed encoding makes the KDF input injective over distinct component secrets. The added cost over the plain combiner is one evaluation of H over τ per party; no round trips, public-key operations, messages, or wire bytes are added (Proposition 4).

6 Security Analysis

We work in the random-oracle model with KDF and H modeled as random oracles; component KEM advantages are in the standard IND-CCA sense. Full proofs are in Appendix A; a quantum-random-oracle sketch is in Appendix B.

Lemma 1 (Correctness) *In an honest, unmodified handshake on the hybrid suite, I and R derive the same session key and I accepts, except with probability at most $\delta_{\text{MLKEM}} \approx 2^{-164}$, the ML-KEM-768 decapsulation-failure probability [2].*

When no message is rewritten, $\tau_I = \tau_R$, so both inputs to KDF coincide and the tag check passes; the only failure mode is ML-KEM decapsulation failure.

Theorem 2 (Strongest-link IND-CCA) *Let the hybrid KEM use the bound combiner of Equation (2) with KDF a random oracle. For any efficient adversary $\mathcal{A}$ making at most q_H random-oracle queries,*

$$\text{Adv}_{\text{hyb}}^{\text{ind-cca}}(\mathcal{A}) \leq \min(\text{Adv}_{\text{pq}}^{\text{ind-cca}}(\mathcal{B}_{\text{pq}}), \text{Adv}_{\text{ec}}^{\text{ind-cca}}(\mathcal{B}_{\text{ec}})) + \frac{q_H}{2^\gamma},$$

where $\gamma = \min(|K_{\text{pq}}|, |K_{\text{ec}}|)$ in bits, and $\mathcal{B}_{\text{pq}}, \mathcal{B}_{\text{ec}}$ are explicit reductions running in essentially the same time as $\mathcal{A}$.

The min form is deliberately conservative: breaking the hybrid requires recovering at least one component secret, so the advantage is bounded by the advantage against the harder component. Independence would give the tighter product $\text{Adv}_{\text{pq}} \cdot \text{Adv}_{\text{ec}}$, which we do not assume. This is the split-key argument of Giacon et al. [27]; our contribution is the explicit $q_H/2^\gamma$ constant for this concrete combiner, together with its empirical corroboration in Section 8. Bindel et al. [28] prove that hash-based combiners of this form retain the strongest-link guarantee in the QROM, with bounds degraded by the standard square-root factor from Grover search; the construction inherits that qualitative QROM security, and Appendix B sketches the lifting argument. A tight QROM constant for the explicit bound is left to future work.

Theorem 3 (Two-sided downgrade resilience) *Against the adversary of Definition 1:*

- (i) *for the plain combiner, there exists an adversary achieving $\text{Adv}^{\text{dr}} = 1$;*
- (ii) *for the bound combiner, $\text{Adv}^{\text{dr}} \leq q_H/2^n + \text{Adv}_{\text{MAC}}^{\text{euf-cma}}$, where n is the transcript-hash output length.*

With $n = 256$ (SHA3-256), the dominant term is $q_H/2^{256} < 2^{-190}$ for any realistic query budget. The result is information-theoretic up to the collision and forgery terms: it holds against computationally unbounded adversaries, and for quantum adversaries 2^n should be read as $2^{n/2}$ in the worst case.

Proposition 4 (Binding cost) *Compared to the plain combiner, the bound combiner adds exactly one evaluation of H over τ per party, and no additional public-key operations, messages, round trips, or transmitted bytes.*

7 Implementation and Engineering Considerations

7.1 Reference implementation and toolchain

We provide a reference implementation of both combiners that executes the full protocol of Algorithm 1. The post-quantum component is ML-KEM-768 through a reference implementation of FIPS 203 [40]; X25519 is a vetted constant-time library; and the symmetric primitives are the SHA3-family functions of Section 2.1. The two combiners share one code path and differ only in the key-schedule and confirmation-tag inputs, so that any measured difference is attributable to transcript binding alone. All functional

experiments—correctness, downgrade, and the exposed-component distinguisher—run against this implementation with fixed, logged seeds.

7.2 Constant-time and side-channel considerations

Because the target is constrained devices, we state the side-channel surface of the added mechanism explicitly. The transcript τ is public: it consists of advertised suite lists, the selected suite, and the public keys and ciphertext already sent on the wire. Computing $H(\tau)$ therefore processes only attacker-observable data and introduces no secret-dependent branch or memory access, so it adds no confidentiality-relevant leakage surface over the plain combiner. The key-confirmation check compares MAC tags; our implementation uses a constant-time comparison, so tag verification does not leak the number of matching bytes. The session-key derivation mixes the transcript hash with the two secret shared values inside a single KDF call whose leakage profile is that of the underlying SHA3 permutation, unchanged by the added public input.

The confidentiality-critical leakage in this construction is entirely inside the component primitives, not in the combiner. Any deployment that requires side-channel resistance must use a hardened ML-KEM and a constant-time X25519; the relevant literature includes masked Kyber at first and higher orders [36, 37], masking-conversion techniques [38], and attacks that motivate them [39]. This sets the scale for the binding overhead: a first-order masked ML-KEM-768 decapsulation on Cortex-M4 costs roughly 3.0 million cycles [37], about an order of magnitude more than one transcript hash over the full negotiation. Transcript binding is thus negligible precisely in the hardened deployments where side-channel cost dominates.

7.3 Cost-model methodology

We are explicit that the device-cost figures in Section 8 are a calibrated analytic model, not measurements taken on a single instrumented board running the whole protocol. The model composes published per-primitive Cortex-M4F measurements: ML-KEM-768 cycle counts and peak stack from the `pqm4 m4fspeed` benchmarks on an STM32F4-class core [19], and X25519 scalar-multiplication cost from Lenngren’s optimized Cortex-M4 implementation [20]. The transcript-hash cost is derived from the optimized Keccak- f permutation count (12,969 cycles) used by ML-KEM’s own hashing on the same core, applied to the number of SHA3-256 blocks spanned by τ . Compute energy uses an STM32L4 operating point (80 MHz, 33 mW); radio energy uses an IEEE 802.15.4-class model (4.8 μ J per byte); the CR2032 budget uses a nominal 225 mAh at 3 V with 80% usable capacity. Because the two cycle inputs come from independent measurement campaigns on comparable Cortex-M4F cores, absolute figures should be read as a calibrated model; the relative comparisons that carry the argument—binding versus baseline, compute versus radio—are platform-independent. Reproducing these figures on a single instrumented board is the natural next step and is the main threat to external validity (Section 9).

Table 3 Claim taxonomy. P: proven; M: measured or derived from published inputs; F: future work.

Claim	Basis	Type
Plain combiner downgraded w.p. 1	Thm. 3(i), E2	P/M
Bound combiner aborts every downgrade	Thm. 3(ii), E2	P/M
Strongest-link bound with $q_H/2^\gamma$ term	Thm. 2, E3	P/M
Binding = 11.8% compute, 1.5% energy	cost model, E5, E6	M
Peak stack $\approx$ 6.5 KB	pqm4, E5	M
$\approx$ 80 bound-hybrid handshakes/day	E6	M
Two latency regimes	E7	M
Tight QROM constant	—	F

7.4 Mapping onto a lightweight protocol

To make the constrained-device framing concrete, we sketch how the transcript-bound combiner composes with EDHOC [17] without altering EDHOC’s own guarantees. EDHOC already carries the initiator’s ordered suite list `SUITES_I` and maintains running transcript hashes across messages. A hybrid EDHOC cipher suite would name (ML-KEM-768, X25519) as its key-exchange components; the combiner of Equation (2) is invoked when both components’ shared secrets are available, with τ instantiated from the EDHOC transcript hash that already covers `SUITES_I` and the selected suite. In this composition the combiner’s binding is defence-in-depth: EDHOC’s transcript already secures the negotiation, so the two mechanisms agree. The value of combiner-layer binding is realized in the complementary case—a bespoke minimal handshake or a standalone drop-in KEM pairing with no such transcript—where the combiner is the only layer that authenticates the negotiation. The property is thus local to the combiner and does not depend on the embedding protocol being present or correctly configured.

7.5 Claim taxonomy and validation gate

Table 3 classifies every quantitative claim as Proven (P), Measured/derived from published inputs (M), or Future (F). Before any number is reported, a 30-check validation gate must pass; its categories are itemized in Appendix C (Table C1). In the released run the gate passes all 30 checks. All experiments use fixed seeds, logged in the artifact.

8 Results

Figure 1 summarizes the construction and the attack surface.

8.1 Correctness and downgrade resilience (E1, E2)

Over 2,000 honest hybrid handshakes, I and R agreed on the session key with zero mismatches, consistent with Lemma 1. Under the active adversary (Figure 2), the plain combiner was silently downgraded to classical x25519 in every trial, while the bound combiner aborted in every trial. Both outcomes are deterministic under the

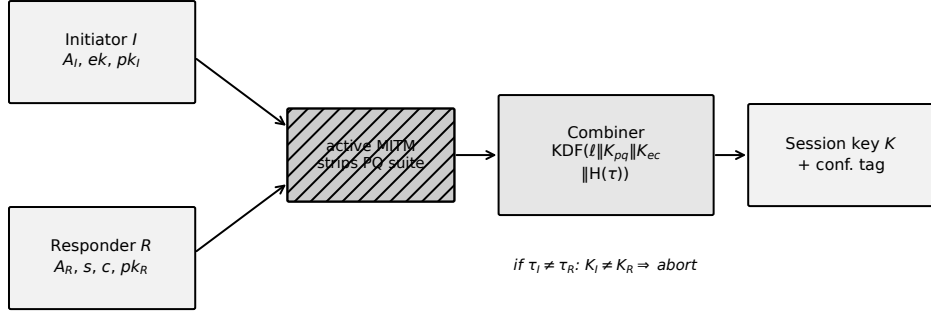


Fig. 1 Transcript-bound hybrid key establishment. The combiner mixes both component secrets and the transcript hash; an active man-in-the-middle who strips the post-quantum suite changes τ , causing $K_I \neq K_R$ and forcing an abort

stated adversary, as Theorem 3 predicts; the repetition over independently sampled KEM and Diffie–Hellman keys serves to rule out implementation non-determinism rather than to estimate a probability, and no variance is expected or observed.

8.2 Strongest-link distinguisher (E3)

To verify the $q_H/2^\gamma$ term in Theorem 2 empirically, we ran an exposed-component distinguisher: one component secret is revealed in full, and the adversary makes q random guesses of the other over a reduced $\gamma = 14$ -bit space, winning if any guess reproduces the session key. Figure 3 shows the empirical success rate against the analytic $q/2^\gamma$ line, with 95% Wilson intervals over 2,000 independent seeds per point. A least-squares fit through the origin has slope 5.91×10^{-5} against the analytic 6.10×10^{-5} (ratio 0.97) with $R^2 = 0.98$; every analytic value lies within the empirical confidence interval. Extrapolated to the full $\gamma = 256$ bits with $q_H = 2^{64}$, the success probability is below 2^{-190} . As construction sanity checks, KDF outputs were statistically uniform (monobit fraction 0.499) when one secret was known, and the SHA3-256 known-answer test passed.

8.3 Computation and communication (E5)

Figure 4 reports handshake computation from the cost model of Section 7.3. The bound hybrid totals 4.43 M cycles across both parties, against 3.96 M for the plain hybrid; transcript binding adds 0.47 M cycles, or 11.8%. The hybrid handshake places 2,386 bytes on the wire (Figure 5); binding adds none. Peak stack is 6,468 bytes, dominated by ML-KEM-768 and within the Class-2 constrained-node memory budget (Table 4). The model is internally consistent: the plain-hybrid cycle count is exactly the sum of the ML-KEM-only and X25519-only handshakes, since the hybrid performs the union of their operations.

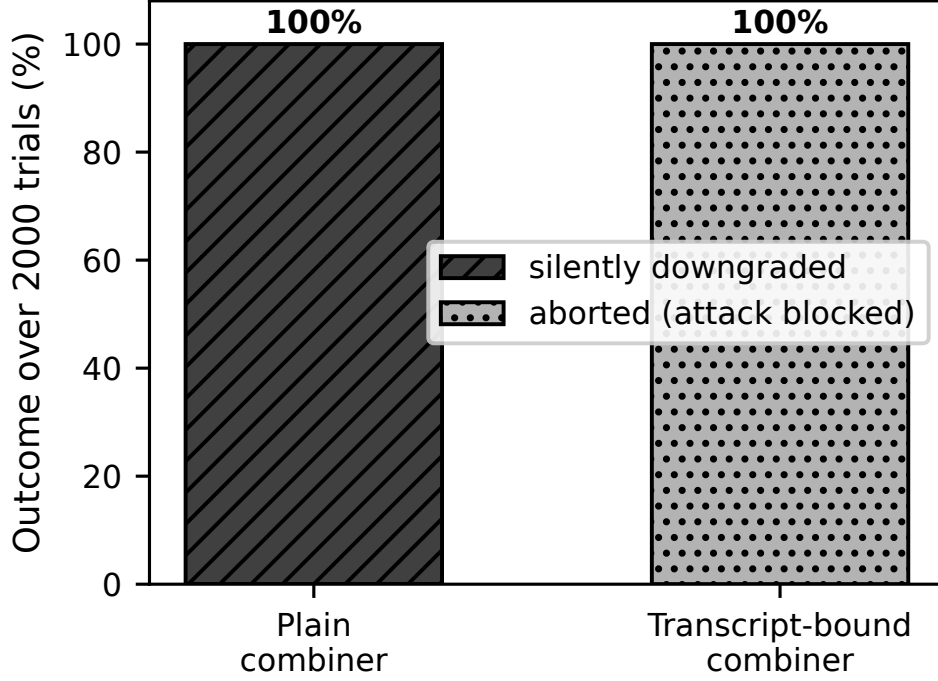


Fig. 2 Downgrade outcome across 2,000 trials. The plain combiner is silently degraded to the classical suite in every trial; the transcript-bound combiner aborts every attempt

Table 4 Per-handshake cost (both parties combined). Cycle counts and peak stack composed from published Cortex-M4 inputs; energy is split into compute and 802.15.4-class radio

Scheme	Bytes	Mcyc	Stack (B)	Energy (mJ)
X25519 only	114	2.50	1000	1.58
ML-KEM-768 only	2322	1.46	6468	11.75
Hybrid (plain)	2386	3.96	6468	13.09
Hybrid (bound)	2386	4.43	6468	13.28

8.4 Energy (E6)

Figure 6 separates compute from radio energy. For the bound hybrid, compute accounts for 1.83 mJ and radio for 11.45 mJ, making radio 86% of the 13.28 mJ total. Transcript binding is 11.8% of compute energy but only 1.5% of the total handshake budget. The dominant post-quantum cost on a constrained radio link is transmitting the larger ML-KEM-768 key material and ciphertext, not the binding hash. On a five-year CR2032 budget, the radio-inclusive energy supports about 80 bound-hybrid

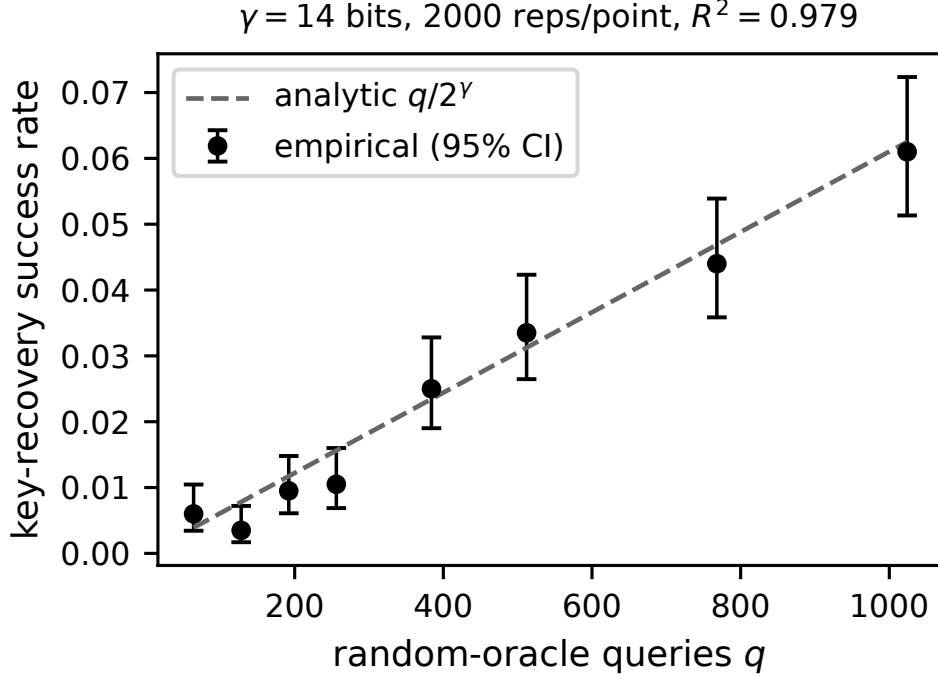


Fig. 3 Exposed-component distinguisher with 95% confidence intervals. With one component fully broken, key-recovery success grows as $q/2^\gamma$; the fitted slope tracks the analytic line ($R^2 = 0.98$) and extrapolates below 2^{-190} at full parameters

handshakes per day, against 91 for ML-KEM-768 alone and 675 for X25519 alone (Figure 7); the hybrid and ML-KEM-only figures are close because both are dominated by the ML-KEM-768 payload.

8.5 Latency and security level (E7)

A latency projection over published round-trip datasets [41] shows two regimes (Figure 8): wide-area handshakes are network-bound (about 208 ms total), while edge handshakes are compute-bound and cluster near 36 ms. These are projections over real latency data, not measurements of a deployed system. Across ML-KEM security levels (Figure 9), level 768 sits at the efficiency knee: it provides NIST Category-3 security at modest incremental compute energy over level 512, while level 1024 offers a margin most constrained deployments do not require.

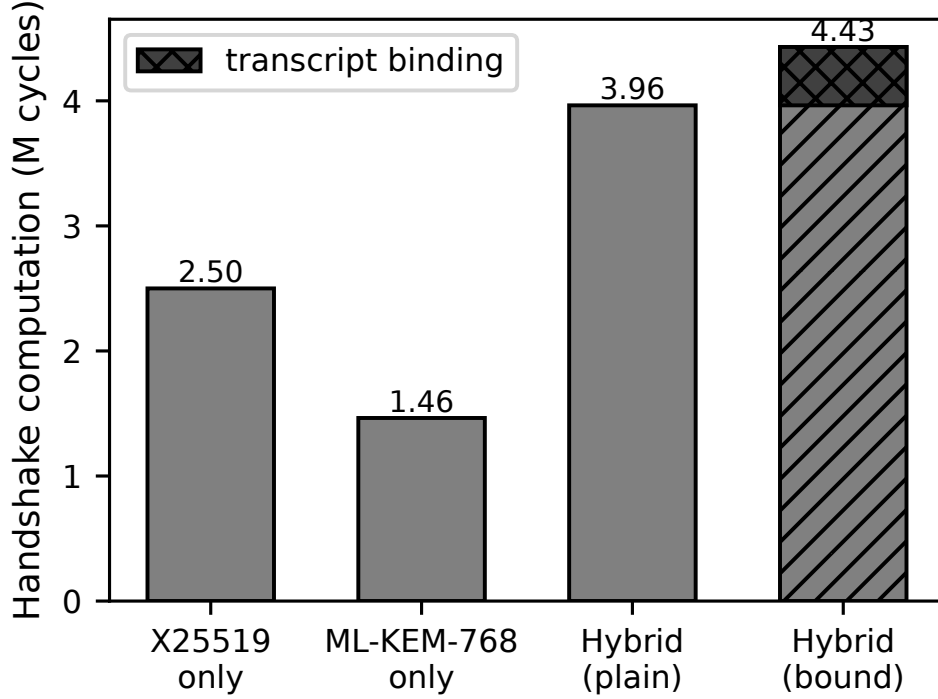


Fig. 4 Handshake computation from composed Cortex-M4 per-primitive measurements (pqm4 ML-KEM-768; Lenngren X25519). Transcript binding adds one hash evaluation per party

9 Discussion

Why the defence works.

The construction reduces to one invariant: the session key is a function of the negotiation transcript, so any party that accepts has committed to exactly what it observed on the wire. Theorem 3(ii) makes this precise, and the empirical result follows from the theorem rather than from an implementation detail. The plain combiner fails for the complementary reason: its key schedule is blind to the advertised lists, so an attacker who rewrites them leaves no trace in the key. This is the transcript-authentication principle of TLS 1.3 and EDHOC [15–17], applied one layer lower, in the combiner itself.

When binding is necessary versus defence-in-depth.

When a hybrid KEM is embedded in TLS 1.3, IKEv2, or EDHOC, the protocol already authenticates the transcript and provides downgrade resilience; combiner-layer binding is then defence-in-depth. Binding is *necessary* precisely when the embedding provides no such guarantee: a standalone drop-in KEM used outside a transcript-authenticating protocol, a bespoke raw-KEM pairing in a custom constrained handshake, or an

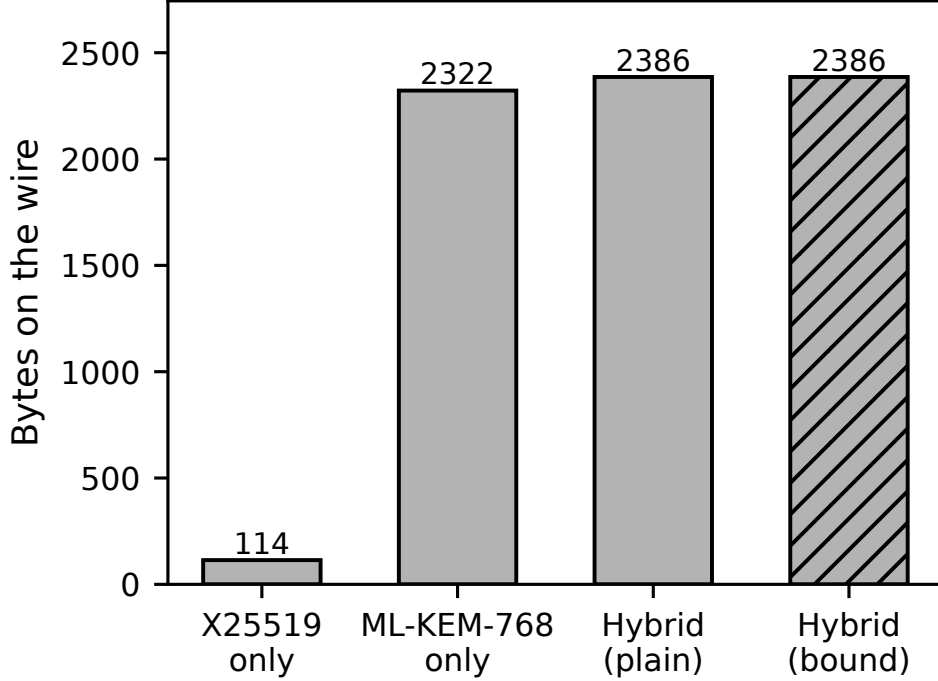


Fig. 5 Bytes on the wire. The transcript-bound and plain hybrid handshakes are identical in communication cost; binding adds no transmitted bytes

early hybrid prototype. In those settings, binding makes downgrade resilience a self-contained property of the combiner, independent of whether the surrounding protocol is present and correctly configured, at the cost of one hash.

Relation to X-Wing.

X-Wing [18] and this construction answer different questions and are not in competition. X-Wing is a fixed combined KEM with no notion of negotiation; it is secure by construction when its inputs are fixed and is intended as a drop-in replacement for a single KEM. The present combiner adds the negotiation transcript to the key schedule so that the choice of suite, not only the shared secrets, is authenticated. A deployment that uses X-Wing inside a protocol with its own transcript binding needs nothing further; one that performs in-band suite selection without that binding gains exactly the missing guarantee from Equation (2).

Limitations.

The strongest-link bound is proven in the classical random-oracle model; the QROM guarantee is qualitative, with only a sketch in Appendix B. The device figures are a calibrated model composed from published per-primitive Cortex-M4F measurements

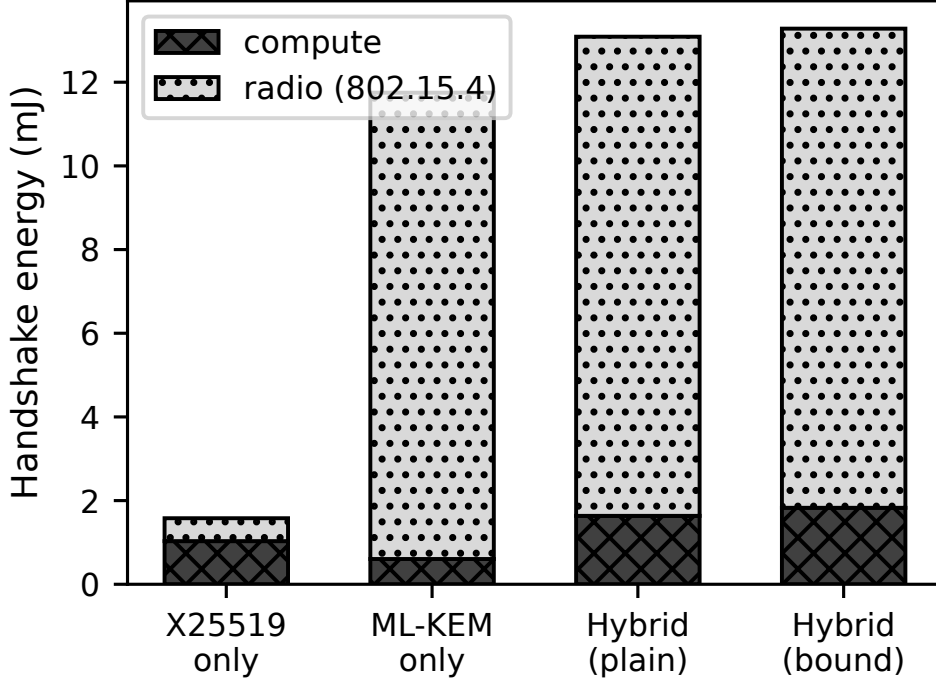


Fig. 6 Total handshake energy split by compute and radio. Radio transmission dominates; the transcript-binding overhead is a small fraction of total energy

from two campaigns, not a single instrumented deployment. The construction authenticates the integrity of the negotiated parameters and assumes entity authentication is provided separately; without it, a man-in-the-middle running two independent handshakes is outside the model. Finally, transcript binding captures negotiation integrity but not availability: an attacker can still force an abort by corrupting messages, which is a denial-of-service outcome, not a downgrade.

Threats to validity.

Internally, composing ML-KEM and X25519 cycle counts from two independent campaigns on comparable cores means absolute figures carry that caveat, although the relative comparisons are platform-independent. Externally, the latency analysis projects computation onto published round-trip datasets rather than measuring a live deployment, and the energy operating points represent a class of 802.15.4-class radios rather than one device. Reproducing the end-to-end cost on a single instrumented board is the highest-value next step.

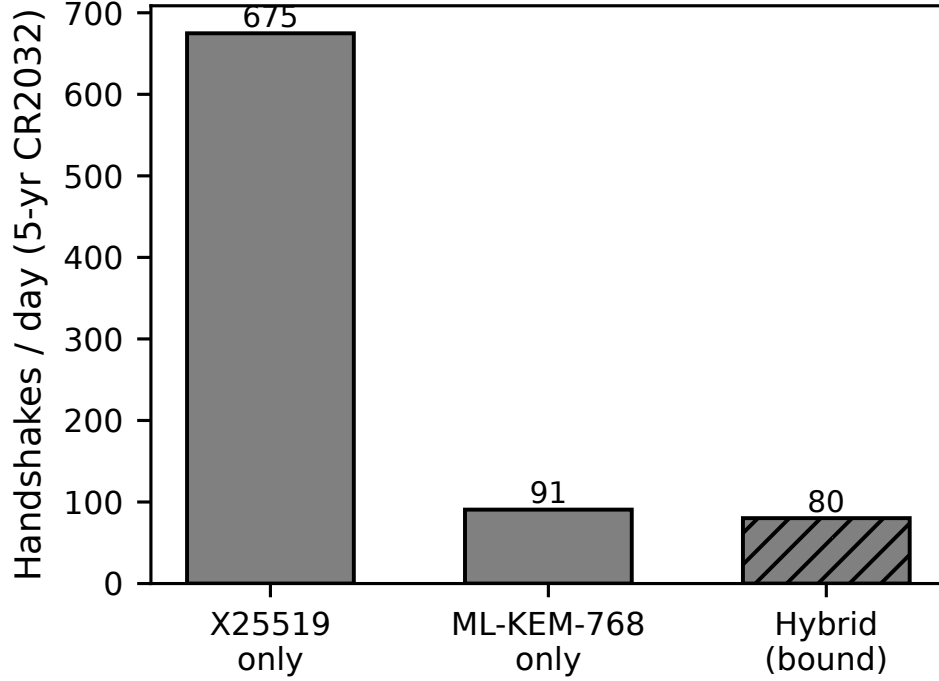


Fig. 7 Handshakes per day on a five-year CR2032 budget, radio-inclusive. The hybrid budget is dominated by the ML-KEM-768 payload, not by transcript binding

10 Conclusion

Hybrid key establishment secures the derived session key under the assumption that one component primitive survives, but it does not secure the negotiation that decides which primitives are used. A hybrid KEM proven secure as a fixed object gives no guarantee against an attacker who strips the post-quantum option, particularly when the combiner is deployed outside a protocol that authenticates the transcript. We defined downgrade resilience at the combiner layer, proved a two-sided separation between the plain and transcript-bound key schedules, and gave an explicit strongest-link bound corroborated by a distinguisher that tracks its analytic term. On a calibrated Cortex-M4 cost model with a radio-inclusive energy account, the defence costs one transcript hash: 11.8% of compute and 1.5% of total handshake energy, with no additional messages or bytes. For the constrained post-quantum deployments where protocol-level transcript authentication is absent or unreliable, this is a minimal, local, and self-contained way to close the downgrade gap.

Future work includes deriving a tight QROM constant for the transcript-bound combiner, extending the model to multi-session settings with session-state reveal, applying the principle to three-or-more component combiners for post-quantum agility,

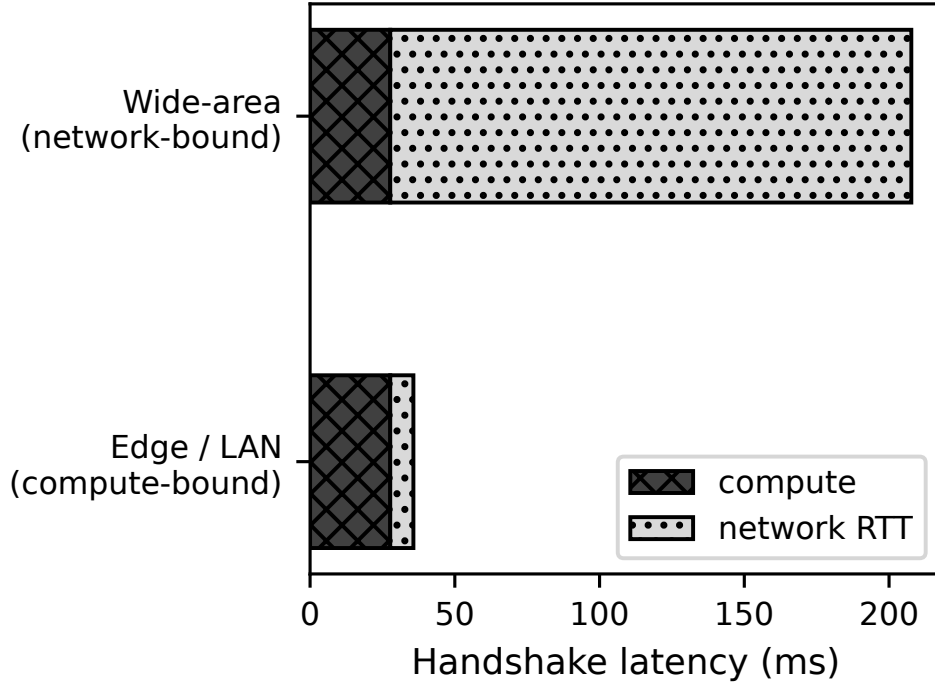


Fig. 8 Latency projection over published round-trip datasets. Wide-area handshakes are network-bound; edge handshakes are compute-bound

replacing the analytic energy model with power-instrumented single-board measurements, and integrating the combiner into a complete EDHOC extension evaluated against the existing cipher-suite negotiation.

Supplementary information. The reference implementation, all experiment scripts, generated result files, figure-generation code, and the 30-check validation gate are provided as an accompanying software artifact.

Acknowledgements. Not applicable.

Declarations

Funding. No funding was received for conducting this study.

Competing interests. The authors have no competing interests to declare that are relevant to the content of this article.

Ethics approval and consent to participate. Not applicable.

Consent for publication. Not applicable.

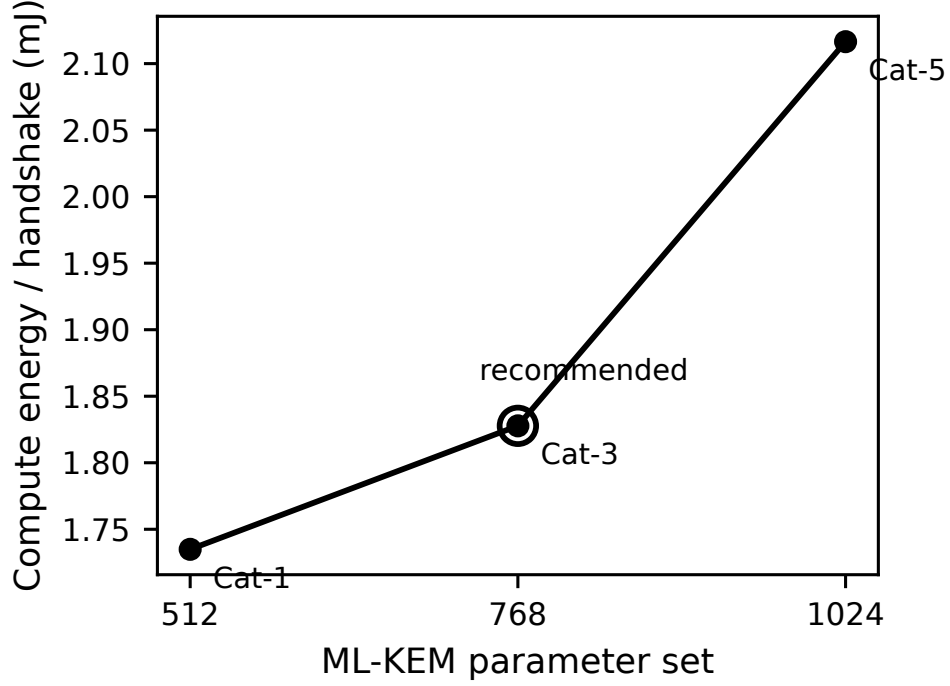


Fig. 9 Security level versus per-handshake compute energy across ML-KEM parameter sets. ML-KEM-768 is the recommended operating point

Data availability. The benchmarking inputs are derived from the publicly available pqm4 Cortex-M4 measurements and published round-trip latency datasets. No new empirical datasets were generated.

Materials availability. Not applicable.

Code availability. The protocol harness, experiment scripts, cost model, figure-generation code, and validation gate are available from the authors and will be released in a public repository upon acceptance.

Author contribution. B. Gupta developed the construction, proofs, implementation, and experiments, and wrote the manuscript. S. Rana supervised the work and revised the manuscript. Both authors reviewed and approved the final version.

Use of AI tools. An AI-based tool was used for language copy-editing (readability and grammar) only. All definitions, theorems, proofs, implementation, and reported numbers were produced and verified by the authors; no results were generated by an AI tool.

Appendix A Full Proofs

Proof of Lemma 1.

On an honest, unmodified hybrid handshake, I and R observe the same message sequence, so $\tau_I = \tau_R$. ML-KEM-768 decapsulation returns the encapsulated K_{pq} except with probability $\delta_{MLKEM} \approx 2^{-164}$ [2], and X25519 yields equal K_{ec} deterministically. Both KDF inputs coincide, so $K_I = K_R$, and the tag check $\text{MAC}(K_I, \tau_I) = t_R$ holds. The only failure mode is ML-KEM decapsulation failure. $\square$

Proof of Theorem 2.

Game 0 is the standard IND-CCA game for the hybrid KEM. Let **Query** be the event that $\mathcal{A}$ queries KDF at the challenge point $\ell \parallel K_{pq} \parallel K_{ec} \parallel H(\tau)$. In Game 1 the challenger samples the session key uniformly and independently of the challenge ciphertext; Games 0 and 1 are identical unless **Query** occurs, so $\text{Adv}_0 \leq \text{Adv}_1 + \Pr[\text{Query}]$, and since the Game-1 key is independent of the challenge bit, $\text{Adv}_1 = 0$.

Reduction $\mathcal{B}_{pq}$ receives an ML-KEM-768 IND-CCA challenge (ek^*, c^*, K_b^*) , plants it as the post-quantum component, answers hybrid decapsulation queries with its own ML-KEM oracle for all $c \neq c^*$, and monitors $\mathcal{A}$'s KDF queries. If any query contains the challenge K_{pq}^* in the correct field, $\mathcal{B}_{pq}$ distinguishes K_b^* . Hence $\Pr[\text{Query} \wedge K_{pq} \text{ unknown}] \leq \text{Adv}_{pq}$; symmetrically $\Pr[\text{Query} \wedge K_{ec} \text{ unknown}] \leq \text{Adv}_{ec}$. The remaining $q_H/2^\gamma$ term bounds the probability of guessing an unqueried γ -bit secret. Taking the min over both reductions gives the bound. $\square$

Proof of Theorem 3.

(i) The adversary intercepts A_I before it reaches R and removes every post-quantum entry, forwarding $A'_I = \{\text{x25519}\}$. R selects x25519, computes K_{ec} , and sets $K_{pq} = \varepsilon$. The plain key $K = \text{KDF}(K_{pq} \parallel K_{ec})$ depends only on K_{ec} , not on A_I , A'_I , or the selected suite. I computes K from the same K_{ec} , both parties accept on x25519, and the weaker-suite event holds with probability 1.

(ii) A successful downgrade requires an honest session to accept on a transcript $\tau_I \neq \tau_R$ (since $\mathcal{A}$ altered the negotiation) while $\text{MAC}(K_I, \tau_I) = t_R$, where $t_R = \text{MAC}(K_R, \tau_R)$ and $K_R = \text{KDF}(\ell \parallel K_{pq} \parallel K_{ec} \parallel H(\tau_R))$. If $H(\tau_I) = H(\tau_R)$, then $\mathcal{A}$ found a hash collision, with probability at most $q_H/2^n$ in the random-oracle model. Otherwise $K_I \neq K_R$ (distinct random-oracle inputs), and matching a tag computed under the independent K_R requires an EUF-CMA forgery, with probability at most $\text{Adv}_{\text{MAC}}^{\text{euf-cma}}$. Summing gives the bound. $\square$

Proof of Proposition 4.

The two combiners share one protocol skeleton. The bound variant adds one H evaluation over τ per party before the KDF call and uses τ rather than a constant as the MAC input. No key generation, encapsulation, decapsulation, message, round trip, or wire byte is added. $\square$

Table C1 Validation-gate categories. All checks pass in the released run

Category	What it verifies	Checks
Correctness	honest handshakes agree; key length; suite selection	6
Downgrade	plain downgraded, bound aborts, no false abort	8
Distinguisher	fit slope vs analytic, R^2 , monotonicity, CIs	6
Cost model	binding increment, wire-byte parity, additivity	4
Known-answer	SHA3-256 KAT, uniformity, determinism, sensitivity	4
Footprint	peak stack within budget, wire size bound	2
Total		30

Appendix B Quantum Random-Oracle Sketch

We sketch why the strongest-link guarantee survives a quantum adversary that queries H and KDF in superposition; a tight constant is left to future work. The key step in Theorem 2 is bounding $\Pr[\text{Query}]$, the probability that the adversary evaluates KDF at the challenge point containing a component secret it does not otherwise recover. In the QROM this probability is bounded using the one-way-to-hiding (O2H) framework and its semi-classical-oracle refinement [42, 43]: the difference between the real and the reprogrammed oracle is bounded by the square root of the probability that a measured query hits the reprogrammed point. Instantiating the O2H bound with the guessing probability $q_H/2^\gamma$ replaces that term by $O(q_H/2^{\gamma/2})$, the expected Grover-style degradation, and leaves the component-KEM reductions intact because ML-KEM’s own IND-CCA analysis is already QROM-sound [6, 21]. Bindel et al. [28] carry out the analogous lifting for hash-based hybrid combiners in full; our combiner is of that form. For downgrade resilience (Theorem 3(ii)), the collision term $q_H/2^n$ becomes $O(q_H^3/2^n)$ under the standard quantum collision bound, which for $n = 256$ remains below 2^{-100} for any realistic q_H .

Appendix C Validation-Gate Categories

Table C1 itemizes the 30-check validation gate that must pass before any quantitative result is reported. In the released run all 30 checks pass.

Appendix D Ablation: Binding Overhead versus Negotiation Size

Figure D1 shows that transcript-binding overhead, as a fraction of total handshake compute, is essentially flat as the number of advertised suites grows. The transcript hash spans the fixed public-key and ciphertext material plus a few identifier bytes per advertised suite, so the number of Keccak- f permutations grows slowly, and the ML-KEM-768 payload always dominates. The overhead stays near 12% regardless of negotiation complexity, so the defence does not become the bottleneck as negotiations grow.

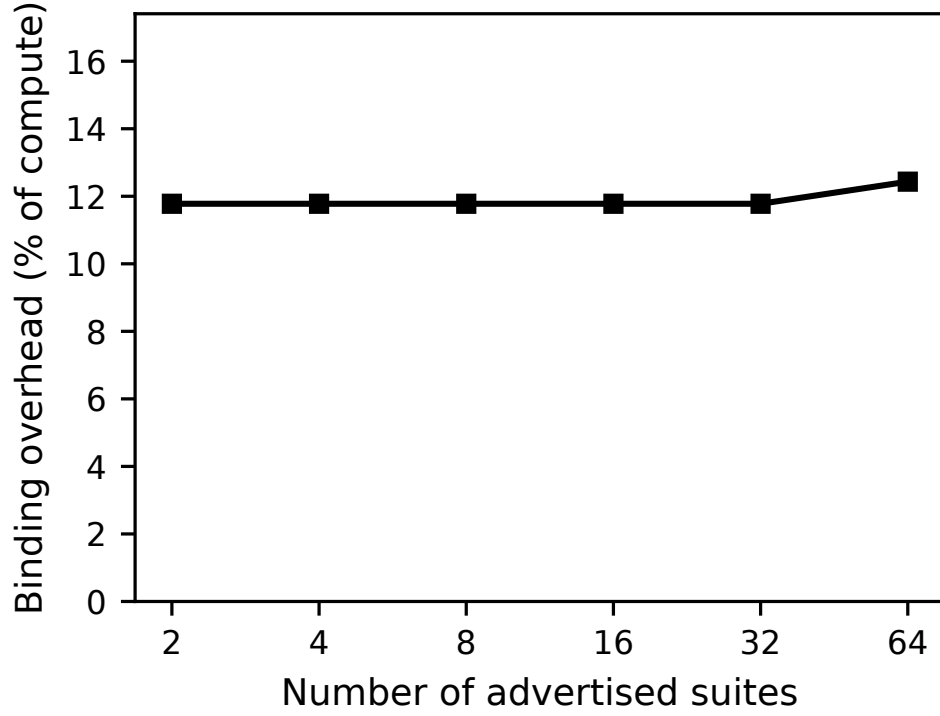


Fig. D1 Transcript-binding overhead as a fraction of handshake compute, versus the number of advertised suites. The overhead is dominated by a single short Keccak hash and remains near 12%

References

- [1] Shor, P.W.: Polynomial-time algorithms for prime factorization and discrete logarithms on a quantum computer. *SIAM J. Comput.* **26**(5), 1484–1509 (1997) <https://doi.org/10.1137/S0097539795293172>
- [2] National Institute of Standards and Technology: Module-lattice-based key-encapsulation mechanism standard. FIPS Publication 203, U.S. Department of Commerce (2024). <https://doi.org/10.6028/NIST.FIPS.203>
- [3] National Institute of Standards and Technology: Module-lattice-based digital signature standard. FIPS Publication 204, U.S. Department of Commerce (2024). <https://doi.org/10.6028/NIST.FIPS.204>
- [4] National Institute of Standards and Technology: Stateless hash-based digital signature standard. FIPS Publication 205, U.S. Department of Commerce (2024). <https://doi.org/10.6028/NIST.FIPS.205>

- [5] Alagic, G., et al.: Status report on the third round of the NIST post-quantum cryptography standardization process. NIST IR 8413, National Institute of Standards and Technology (2022). <https://doi.org/10.6028/NIST.IR.8413>
- [6] Bos, J., Ducas, L., Kiltz, E., Lepoint, T., Lyubashevsky, V., Schanck, J.M., Schwabe, P., Seiler, G., Stehlé, D.: CRYSTALS-Kyber: A CCA-secure module-lattice-based KEM. In: IEEE European Symposium on Security and Privacy (EuroS&P), pp. 353–367 (2018). <https://doi.org/10.1109/EuroSP.2018.00032>
- [7] Castryck, W., Decru, T.: An efficient key recovery attack on SIDH. In: Advances in Cryptology – EUROCRYPT 2023. LNCS, vol. 14008, pp. 423–447. Springer, ??? (2023). https://doi.org/10.1007/978-3-031-30589-4_15
- [8] Bernstein, D.J., Lange, T.: Post-quantum cryptography. In: Nature, vol. 549, pp. 188–194 (2017). <https://doi.org/10.1038/nature23461>
- [9] Alkim, E., Ducas, L., Pöppelmann, T., Schwabe, P.: Post-quantum key exchange—a new hope. In: 25th USENIX Security Symposium, pp. 327–343 (2016)
- [10] Bos, J., Costello, C., Ducas, L., Mironov, I., Naehrig, M., Nikolaenko, V., Raghunathan, A., Stebila, D.: Frodo: Take off the ring! practical, quantum-secure key exchange from LWE. In: ACM SIGSAC Conference on Computer and Communications Security (CCS), pp. 1006–1018 (2016). <https://doi.org/10.1145/2976749.2978425>
- [11] Paquin, C., Stebila, D., Tamvada, G.: Benchmarking post-quantum cryptography in TLS. In: Post-Quantum Cryptography (PQCrypto 2020). LNCS, vol. 12100, pp. 72–91. Springer, ??? (2020). https://doi.org/10.1007/978-3-030-44223-1_5
- [12] Sikeridis, D., Kampanakis, P., Devetsikiotis, M.: Post-quantum authentication in TLS 1.3: A performance study. In: Network and Distributed System Security Symposium (NDSS) (2020). <https://doi.org/10.14722/ndss.2020.24203>
- [13] Stebila, D., Fluhrer, S., Gueron, S.: Hybrid Key Exchange in TLS 1.3. IETF Internet-Draft draft-ietf-tls-hybrid-design (2024)
- [14] Adrian, D., *et al.*: Imperfect forward secrecy: How Diffie-Hellman fails in practice. In: ACM SIGSAC Conference on Computer and Communications Security (CCS), pp. 5–17 (2015). <https://doi.org/10.1145/2810103.2813707>
- [15] Rescorla, E.: The Transport Layer Security (TLS) Protocol Version 1.3. RFC 8446, IETF (2018). <https://doi.org/10.17487/RFC8446>
- [16] Bhargavan, K., Brzuska, C., Fournet, C., Green, M., Kohlweiss, M., Zanella-Béguelin, S.: Downgrade resilience in key-exchange protocols. In: IEEE Symposium on Security and Privacy (S&P), pp. 506–525 (2016). <https://doi.org/10.1109/S&P.2016.7717001>

- [17] Selander, G., Mattsson, J.P., Palombini, F.: Ephemeral Diffie-Hellman Over COSE (EDHOC). RFC 9528, IETF (2024). <https://doi.org/10.17487/RFC9528>
- [18] Barbosa, M., Connolly, D., Duarte, J.D., Kaiser, A., Schwabe, P., Varner, K., Westerbaan, B.: X-Wing: The Hybrid KEM You’ve Been Looking For. IACR Communications in Cryptology, vol. 1, no. 1 (2024). <https://doi.org/10.62056/a3qj89n4e>
- [19] Kannwischer, M.J., Petri, R., Rijneveld, J., Schwabe, P., Stoffelen, K.: pqm4: Testing and Benchmarking NIST PQC on ARM Cortex-M4. <https://github.com/mupq/pqm4> (2024)
- [20] Lenngren, E.: AArch32/Cortex-M4 Optimized Implementation of X25519. <https://github.com/Emill/X25519-Cortex-M4> (2019)
- [21] Hofheinz, D., Hövelmanns, K., Kiltz, E.: A modular analysis of the Fujisaki-Okamoto transformation. Theory of Cryptography (TCC 2017), LNCS **10677**, 341–371 (2017) https://doi.org/10.1007/978-3-319-70500-2_12
- [22] Langley, A., Hamburg, M., Turner, S.: Elliptic Curves for Security. RFC 7748, IETF (2016). <https://doi.org/10.17487/RFC7748>
- [23] Bernstein, D.J.: Curve25519: New Diffie-Hellman speed records. In: Public Key Cryptography (PKC 2006). LNCS, vol. 3958, pp. 207–228. Springer, ??? (2006). https://doi.org/10.1007/11745853_14
- [24] National Institute of Standards and Technology: SHA-3 standard: Permutation-based hash and extendable-output functions. FIPS Publication 202, U.S. Department of Commerce (2015). <https://doi.org/10.6028/NIST.FIPS.202>
- [25] Krawczyk, H.: Cryptographic extraction and key derivation: The HKDF scheme. In: Advances in Cryptology – CRYPTO 2010. LNCS, vol. 6223, pp. 631–648. Springer, ??? (2010). https://doi.org/10.1007/978-3-642-14623-7_34
- [26] Krawczyk, H., Eronen, P.: HMAC-based Extract-and-Expand Key Derivation Function (HKDF). RFC 5869, IETF (2010). <https://doi.org/10.17487/RFC5869>
- [27] Giacon, F., Heuer, F., Poettering, B.: KEM combiners. In: Public-Key Cryptography (PKC 2018). LNCS, vol. 10769, pp. 190–218. Springer, ??? (2018). https://doi.org/10.1007/978-3-319-76578-5_7
- [28] Bindel, N., Brendel, J., Fischlin, M., Goncalves, B., Stebila, D.: Hybrid key encapsulation mechanisms and authenticated key exchange. In: Post-Quantum Cryptography (PQCrypto 2019). LNCS, vol. 11505, pp. 206–226. Springer, ??? (2019). https://doi.org/10.1007/978-3-030-25510-7_12

- [29] Huguenin-Dumittan, L., Vaudenay, S.: FO-like combiners and hybrid post-quantum cryptography. In: Cryptology and Network Security (CANS 2021). LNCS, vol. 13099, pp. 225–244. Springer, ??? (2021). https://doi.org/10.1007/978-3-030-92548-2_12
- [30] Dowling, B., Hansen, T.B., Paterson, K.G.: Many a mickle makes a muckle: A framework for provably quantum-secure hybrid key exchange. In: Post-Quantum Cryptography (PQCrypto 2020). LNCS, vol. 12100, pp. 483–502. Springer, ??? (2020). https://doi.org/10.1007/978-3-030-44223-1_26
- [31] Schwabe, P., Stebila, D., Wiggers, T.: Post-quantum TLS without handshake signatures. In: ACM SIGSAC Conference on Computer and Communications Security (CCS), pp. 1461–1480 (2020). <https://doi.org/10.1145/3372297.3423350>
- [32] Crockett, E., Paquin, C., Stebila, D.: Prototyping post-quantum and hybrid key exchange and authentication in TLS and SSH. In: NIST 2nd PQC Standardization Conference (2019)
- [33] Bormann, C., Ersue, M., Keranen, A.: Terminology for Constrained-Node Networks. RFC 7228, IETF (2014). <https://doi.org/10.17487/RFC7228>
- [34] Shelby, Z., Hartke, K., Bormann, C.: The Constrained Application Protocol (CoAP). RFC 7252, IETF (2014). <https://doi.org/10.17487/RFC7252>
- [35] Selander, G., Mattsson, J.P., Palombini, F., Seitz, L.: Object Security for Constrained RESTful Environments (OSCORE). RFC 8613, IETF (2019). <https://doi.org/10.17487/RFC8613>
- [36] Bos, J.W., Gourjon, M., Renes, J., Schneider, T., Vredendaal, C.: Masking Kyber: First- and higher-order implementations. IACR Trans. Cryptogr. Hardw. Embed. Syst. (TCHES) **2021**(4), 173–214 (2021) <https://doi.org/10.46586/tches.v2021.i4.173-214>
- [37] Heinz, D., Kannwischer, M.J., Land, G., Pöppelmann, T., Schwabe, P., Sprenkels, D.: First-order masked Kyber on ARM Cortex-M4. In: Cryptology ePrint Archive, Paper 2022/058 (2022)
- [38] Bronchain, O., Cassiers, G.: Bitslicing arithmetic/boolean masking conversions for fun and profit with application to lattice-based KEMs. IACR Trans. Cryptogr. Hardw. Embed. Syst. (TCHES) **2022**(4), 553–588 (2022) <https://doi.org/10.46586/tches.v2022.i4.553-588>
- [39] Ngo, K., Dubrova, E., Guo, Q., Johansson, T.: A side-channel attack on a masked IND-CCA secure Saber KEM implementation. IACR Trans. Cryptogr. Hardw. Embed. Syst. (TCHES) **2021**(4), 676–707 (2021) <https://doi.org/10.46586/tches.v2021.i4.676-707>

- [40] Bell, G.: kyber-py: A Pure-Python Implementation of ML-KEM (FIPS 203). <https://github.com/GiacomoPope/kyber-py> (2024)
- [41] PlanetLab / iPlane Round-Trip Latency Datasets: Wide-Area and Edge Round-Trip Time Measurements. Publicly available network-latency datasets (2020)
- [42] Unruh, D.: Revocable quantum timed-release encryption. In: Advances in Cryptology – EUROCRYPT 2014. LNCS, vol. 8441, pp. 129–146. Springer, ??? (2014). https://doi.org/10.1007/978-3-642-55220-5_8
- [43] Ambainis, A., Hamburg, M., Unruh, D.: Quantum security proofs using semi-classical oracles. In: Advances in Cryptology – CRYPTO 2019. LNCS, vol. 11693, pp. 269–295. Springer, ??? (2019). https://doi.org/10.1007/978-3-030-26951-7_10